Quantum Bill of Materials — Engagement Report

Acme Corp

Engagement 866ae41d-1f56-49fd-ac2d-169349c8e460 · created 2026-09-27T05:53:24.995218+00:00 · status TARGET_MET
Prepared in the format recommended by CERT-In's Technical Guidelines on SBOM | QBOM & CBOM | AIBOM | HBOM, Version 2.0 (09.07.2025), Section 8 (Quantum BOM & Cryptographic BOM) and Section 6 (Vulnerability Tracking and Analysis / VEX).

1 · Engagement commitment

Accepted by: Priya Sharma, CISO, on behalf of Acme Corp

Accepted at: 2026-09-27T05:53:24.995708+00:00

Statement: Priya Sharma, CISO, on behalf of Acme Corp, authorises a Quantum Bill of Materials assessment of samples/vulnerable-app against a target post-quantum readiness of 80.0%, understanding that raw findings never leave the organisation's own infrastructure (see the zero-trust attestation layer).

Target post-quantum readiness: 80.0% **Max iterations:** 8

2 · Executive summary

Iterations run	5
Starting PQ-readiness	13.2%
Final PQ-readiness	80.6%
Target	80.0%
Outcome	Target reached and engagement completed successfully.

3 · Readiness trend across iterations

Each iteration: (1) scan, (2) threat analysis & recommendations, (3) the organisation reviews the readiness % and either accepts and continues or stops, (4) if continuing, the recommended fixes are applied, and the estate is rescanned.

#	Scanned	Findings	PQ-ready	Shor-vuln.	Grover-weak.	Broken	Decision
1	original	53	13.2%	45.3%	5.7%	35.8%	continue
2	work_root	40	32.5%	37.5%	5.0%	25.0%	continue
3	work_root	39	41.0%	28.2%	5.1%	25.6%	continue
4	work_root	32	68.8%	25.0%	6.2%	0.0%	continue
5	work_root	31	80.6%	12.9%	6.5%	0.0%	target_met

4 · Vulnerability Exploitability eXchange (VEX)

Per CERT-In Section 6 / 8.4.1.6, applied here to post-quantum migration status: each at-risk algorithm is Not Affected, Affected, Fixed, or Under Investigation, as of the latest iteration.

Algorithm	Status	Threat class	Count	Was	Recommended replacement
AES (key size unknown) AES-UNK	Affected	GROVER	2	2	Verify key size; use AES-256
Ed25519 ED25519	Affected	SHOR	1	2	ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
RSA-3072 RSA-3072	Affected	SHOR	1	1	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
X25519 X25519	Affected	SHOR	2	3	Hybrid X25519MLKEM768 now, ML-KEM-768 later
RSA-2048 RSA-2048	Fixed	SHOR	0	1	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
RSA (size unknown) RSA-UNK	Fixed	SHOR	0	1	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

5 · Remediation log

Applied before iteration 2:

- **Restrict nginx to TLS 1.3 with a hybrid PQ key-exchange group** — Dropped TLS 1.0/1.1/1.2 entirely. Added a hybrid classical+ML-KEM group (X25519MLKEM768) alongside the classical fallback. Replaced the legacy dash-separated cipher-suite string (which implied static-RSA key transport and still listed RC4/3DES) with the standard TLS 1.3 suite names.
  `config/nginx.conf`
- **Raise default_bits, drop RC4, add a hybrid PQ group** — default_bits raised to 3072 (classical hygiene only -- RSA of any size stays Shor-vulnerable; this does not by itself move the readiness needle, and the report says so). CipherString no longer names RC4/legacy static-RSA suites. Added a Groups= directive enabling a hybrid ML-KEM group (OpenSSL 3.2+).
  `config/openssl.cnf`
- **Re-issue legacy_partner.crt as ML-DSA-65 (FIPS 204)** — A certificate's signature algorithm cannot be hand-edited -- it is re-issued, exactly as a PKI/CA team would. Signed with ML-DSA-65 (FIPS 204): this is a genuine post-quantum-safe certificate, not an interim step.
  `certs/legacy_partner.crt, certs/legacy_partner.key`

Applied before iteration 3:

- **Migrate payments TLS key EC P-256 -> hybrid X25519+ML-KEM-768** — Same reasoning as the signing key: EC P-256 alone is Shor-breakable, so the replacement is a hybrid KEM, not a different curve.
  `app/payments/service.py`
- **Re-issue modern_service.crt as ML-DSA-65 (FIPS 204)** — modern_service.crt was already today's classical best practice (EC P-256/SHA-256) -- not urgent, which is why this is the lowest-priority action in the catalog. Re-issued as ML-DSA-65 now that PQ certificate tooling is available, completing the wave.
  `certs/modern_service.crt, certs/modern_service.key`
- **Migrate payments signing key RSA-1024 -> ML-DSA-65** — RSA is Shor-breakable at any key size, so this is a real algorithm migration, not a bigger key: signing now uses ML-DSA-65 (FIPS 204) via the liboqs-python API shape.
  `app/payments/service.py`

Applied before iteration 4:

- **Replace MD5/SHA-1 with SHA-256** — Swapped classically-broken digest calls for SHA-256 at each call site. No key-management change needed -- this is a same-shape replacement.
  `app/api/AuthService.java, app/legacy/hash.py, app/payments/service.py, web-service/crypto-utils.js`
- **Replace DES/3DES and ECB mode with AES-256-GCM** — DES/3DES block ciphers and unauthenticated ECB mode replaced with AES-256 in an authenticated (GCM) mode. `encrypt_card_batch` now takes an explicit nonce, matching the AEAD pattern already used elsewhere in this codebase.
  `app/api/AuthService.java, app/payments/service.py, web-service/crypto-utils.js`
- **Harden sshd_config key exchange, ciphers, MACs, host keys** — Dropped diffie-hellman-group1-sha1 and curve25519-sha256 from KexAlgorithms, keeping the already-present hybrid PQ group (sntrup761x25519). Dropped 3des-cbc and hmac-sha1. Dropped the legacy ssh-rsa host key, keeping ssh-ed25519 -- OpenSSH has no standardised post-quantum host-key algorithm yet, so this one item is a documented residual, not a fix.
  `config/sshd_config`

Applied before iteration 5:

- **Migrate vault key-exchange X25519 -> hybrid X25519+ML-KEM-768** — X25519 alone is Shor-breakable; the vault service now negotiates a hybrid classical+PQ group.
  `app/crypto/vault.py`

- **Migrate vault signing key Ed25519 -> ML-DSA-65** — Ed25519 is Shor-breakable; vault signing now uses ML-DSA-65.
  `app/crypto/vault.py`
- **Migrate AuthService key generation RSA -> ML-DSA** — Same reasoning as the Python signing-key migrations: RSA is Shor-breakable at any size, so the fix is an algorithm swap (BouncyCastle-PQC ML-DSA), not a bigger key.
  `app/api/AuthService.java`

6 · Residual items and known limitations

Findings still open at the end of this engagement that are not simply unaddressed -- each has a specific, documented reason automated remediation did not apply:

- **Ed25519** (ED25519): OpenSSH has not standardised a post-quantum host-key algorithm yet. ssh-ed25519 is kept as the strongest currently-interoperable option; revisit when upstream support lands.
- **AES (key size unknown)** (AES-UNK): Key length is supplied at runtime, not as a literal in source, so static analysis cannot confirm 256-bit keys are actually used. Verify operationally (e.g. a runtime assertion or config lint), not with this scanner.
- **RSA-3072** (RSA-3072): default_bits was raised for classical hygiene only. RSA is Shor-vulnerable at any key size, so this has no automated fix short of migrating off RSA entirely -- which the actual signing/TLS call sites already do; this default only affects ad-hoc CSRs generated directly from openssl.cnf.
- **X25519** (X25519): Kept as an explicit classical fallback alongside the configured hybrid group (X25519:X25519MLKEM768) for clients that don't yet support the hybrid group. Removing it would break compatibility with those clients, so it is a deliberate, monitored trade-off, not an oversight.

7 · CERT-In minimum elements (Table 8 & Table 9)

Model Name	Acme Corp — samples/vulnerable-app
Version	engagement 866ae41d-1f56-49fd-ac2d-169349c8e460, iteration 5
Vendor & Origin Information	Internal assessment; component ownership from the org's own manifest, where supplied.
License Information	N/A -- this is an internal cryptographic-asset inventory, not a licensed software component.
Communication Protocol	see Protocols below
Hardware	N/A -- this QBOM/CBOM covers software and configuration cryptographic usage. A companion HBOM would cover physical/hardware cryptographic modules per CERT-In Table 11, which this tool does not scan for.
Software Dependencies	see the scanned component list in the accompanying CycloneDX CBOM export
Environmental Impact	not tracked by this scanner
Vulnerabilities	see the accompanying VEX document (vex.json) for per-algorithm status
Attestations	see attestation.public.json if this scan was run with zero-trust attestation enabled

7.1 · Algorithms

Name	Primitive	Classical security level	Quantum threat class	Occurrence count	Recommended replacement
SHA-256	hash	128 bits	PQ_SAFE	7	none needed
AES-256	block-cipher	256 bits	PQ_SAFE	2	none needed
Hybrid KEM (classical+ML-KEM)	kem	192 bits	HYBRID	5	Later: pure ML-KEM where policy allows
ChaCha20(-Poly1305)	stream-cipher	256 bits	PQ_SAFE	2	none needed
Ed25519	signature	128 bits	SHOR	1	ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
X25519	key-agree	128 bits	SHOR	2	Hybrid X25519MLKEM768 now, ML-KEM-768 later
RSA-3072	pke	128 bits	SHOR	1	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Name	Primitive	Classical security level	Quantum threat class	Occurrence count	Recommended replacement
ML-DSA (44/65/87)	signature	192 bits	PQ_SAFE	7	none needed
AES (key size unknown)	block-cipher	128 bits	GROVER	2	Verify key size; use AES-256

7.2 · Keys

Name	id	state	size
demo-run/workdir/certs/legacy_partner.key	demo-run/workdir/certs/legacy_partner.key:1	active (as scanned; not independently verified)	192 bits (classical security strength)
demo-run/workdir/certs/modern_service.key	demo-run/workdir/certs/modern_service.key:1	active (as scanned; not independently verified)	192 bits (classical security strength)

7.3 · Protocols

Name	Version	Location
TLS 1.3 (hybrid PQ key exchange configured)	TLS1.3-HYBRID	demo-run/workdir/config/nginx.conf:3
TLS 1.3 (hybrid PQ key exchange configured)	TLS1.3-HYBRID	demo-run/workdir/config/openssl.cnf:5

7.4 · Certificates

Name	Signature Algorithm Reference	Subject Public Key Reference	Certificate Format
demo-run/workdir/certs/modern_service.crt	ML-DSA (44/65/87)	ML-DSA (44/65/87)	X.509
demo-run/workdir/certs/legacy_partner.crt	ML-DSA (44/65/87)	ML-DSA (44/65/87)	X.509